Análise e Desenvolvimento de Sistemas — Prof. Emerson Ribeiro de Mello
Segurança da Informação — mello@ifsc.edu.br

Prática: OWASP WebGoat e WebWolf

18/11/2025

Integrantes:
Giuliano Marcus Bianco
Luís Renato Freitas de Almeida
Nicolas Arthur Raulino Oliveira

1 Objetivos

- Configurar e iniciar o ambiente da prática usando Docker Compose
- Acessar as aplicações WebGoat e WebWolf
- Usar o OWASP ZAP para interceptar e analisar requisições HTTP
- Atacar algumas vulnerabilidades do WebGoat

2 Configuração do Ambiente

O ambiente de laboratório é composto por três aplicações principais:

- **WebGoat**: Aplicação web deliberadamente insegura que contém vulnerabilidades comumente encontradas em aplicações Java. É utilizada para aprender e praticar técnicas de segurança web através de exercícios práticos.
- **WebWolf**: Aplicação complementar que simula o ambiente do atacante. Permite receber e-mails, hospedar arquivos e capturar requisições enviadas pelo WebGoat durante os exercícios.
- **OWASP ZAP**: Proxy de segurança para interceptar e analisar requisições HTTP/HTTPS, permitindo identificar vulnerabilidades e testar ataques.

2.1 Arquivo docker-compose.yml

O arquivo de configuração do Docker Compose é apresentado no Listagem 1.

```yaml
services:
  webgoat:
    image: webgoat/webgoat:latest
    container_name: webgoat
    user: "root"
    restart: unless-stopped
    networks: [zapnet]
    ports:
      - "127.0.0.1:9090:9090"
    environment:
      TZ: America/Sao_Paulo
    volumes:
      - webgoat_data:/home/webgoat/.webgoat-2025.3
```

```
  zap:
    image: zaproxy/zap-stable
    container_name: zap
    user: "zap"
    restart: unless-stopped
    networks: [zapnet]
    environment:
      TZ: America/Sao_Paulo
      DISPLAY: ${DISPLAY}
    volumes:
      - /tmp/.X11-unix:/tmp/.X11-unix
      - zap_data:/home/zap/.ZAP
    command: zap.sh

networks:
  zapnet:

volumes:
  zap_data:
  webgoat_data:
```

3 Iniciando o Ambiente

3.1 Iniciar as aplicações

Para iniciar o WebGoat, WebWolf e OWASP ZAP, execute o comando abaixo:

```
docker-compose up --build -d
```

4 Acessando as Aplicações

4.1 Acessando o OWASP ZAP

O OWASP ZAP possui interface gráfica que será exibida automaticamente após a inicialização. O ZAP atua como um *Man-in-the-Middle* (MITM), posicionando-se entre o navegador e o servidor web para interceptar, analisar e modificar o tráfego HTTP/HTTPS. A interface permite visualizar todas as requisições e respostas capturadas.

4.2 Acessando o WebGoat

O WebGoat é a aplicação principal desta prática. Ela contém diversas vulnerabilidades comumente encontradas em aplicações Java. Para acessar o WebGoat:

1. Abra a interface gráfica do OWASP ZAP
2. Use o navegador integrado do ZAP (disponível na interface)
3. No navegador integrado, acesse:

   ```
   http://webgoat:8080/WebGoat
   ```

O navegador integrado do ZAP já está configurado para interceptar automaticamente todo o tráfego HTTP/HTTPS, permitindo analisar as requisições e respostas enviadas pelo WebGoat.

> **! Importante**
>
> Use `webgoat:8080` ao invés de `localhost:8080` no navegador integrado do ZAP, pois as aplicações estão na mesma rede interna e se comunicam pelo nome do serviço.

4.3 Acessando o WebWolf

O WebWolf simula o ambiente do atacante e é utilizado durante os exercícios para receber dados enviados pelo WebGoat. Diferente do WebGoat, o WebWolf deve ser acessado através do navegador na sua máquina local:

1. Abra seu navegador web
2. Acesse:

```
http://localhost:9090/WebWolf
```

O WebWolf permite visualizar e-mails recebidos, arquivos hospedados e requisições capturadas durante os exercícios práticos do WebGoat.

Documento licenciado sob Creative Commons “Atribuição 4.0 Internacional”.